

PROTOCOLO DE PROTECCIÓN DE DATOS DE SALUD Y TELEMETRÍA MÉDICO-LEGAL

Tratamiento Ético de Datos Sintéticos, Auditoría Append-Only e Idempotencia en Código Azul — Normas APA (7.ª Ed.)

LÍDER DE ARQUITECTURA & QA Alan Martinez	FECHA Y VERSIÓN 2026-08-25 Versión 2.0 (Gobernanza Consolidada)	EQUIPO DE DESARROLLO I. Cardozo, F. Sarraute, A. Heredia, M. Silvani	MARCO NORMATIVO Protección de Datos Personales / ISO 27001 / APA 7
---	---	--	--

1. TRATAMIENTO ÉTICO DE DATOS Y USO EXCLUSIVO DE DATOS SINTÉTICOS

En estricto cumplimiento con las normativas éticas de la informática médica y las leyes de protección de datos de salud (Ley 25.326 / HIPAA / GDPR), la **Plataforma Hospitalaria de Código Azul** opera bajo un riguroso esquema de **datos sintéticos y simulados**. Queda absolutamente prohibido el almacenamiento o tratamiento de información real de pacientes o historias clínicas no anonimizadas.

- Privacidad por Diseño (Privacy by Design):** Todos los registros de prueba utilizan identidades de personal médico y sectores de pabellón generados por scripts de semillado (`npm run db:seed`).
- Minimización de Datos:** El sistema no almacena diagnósticos clínicos del paciente, limitándose exclusivamente a la referencia espacial (Pabellón, Sala, Cama) y las marcas temporales del evento.

2. ARQUITECTURA DE AUDITORÍA INMUTABLE (APPEND-ONLY EVENT SOURCING)

Para proporcionar un **blindaje médico-legal inalterable** ante auditorías hospitalarias o investigaciones de mala praxis, se implementa una bitácora desacoplada protegida en el motor de base de datos:

Tabla 1. Garantías de Integridad y Respaldo Médico-Legal en PostgreSQL 18

PROPIEDAD DE AUDITORÍA	IMPLEMENTACIÓN TÉCNICA EN POSTGRESQL 18	GARANTÍA MÉDICO-LEGAL
Inmutabilidad Append-Only	Trigger <code>trg_audit_immutable</code> ejecuta la función <code>fn_prevent_audit_tampering()</code> bloqueando UPDATE y DELETE.	Imposibilidad absoluta de alterar o borrar registros históricos de respuesta médica.
Precisión de Marcas de Tiempo	Tipo nativo <code>TIMESTAMPTZ</code> con resolución de microsegundos en horario UTC.	Trazabilidad fehaciente del instante exacto de disparo, confirmación ACK y resolución.
Flexibilidad de Payloads	Columna semiestructurada <code>payload_data</code> JSONB indexada con GIN.	Almacenamiento detallado de latencias calculadas, identificadores de red y metadatos FCM.
Seguridad Anti-Enumeración	Identificadores UUID v4 criptográficos generados con <code>pgcrypto</code> .	Prevención de ataques de enumeración secuencial de incidentes a través de la API REST.

3. BARRERA DE IDEMPOTENCIA Y MITIGACIÓN DE PULSACIONES REDUNDANTES

En situaciones de alto estrés emocional en salas de emergencia, el personal clínico puede presionar compulsivamente el botón de activación. Para evitar la saturación de los canales de red y proteger la infraestructura del servidor, se implementan las siguientes políticas:

VENTANA DE IDEMPOTENCIA DE 60 SEGUNDOS

Si se recibe una solicitud de activación para una misma cama/sala en un intervalo menor a 60 segundos desde la primera activación activa, el backend no duplica el registro en base de datos ni reemite alertas sonoras redundantes.

Respuesta Sincronizada: La petición redundante retorna el UUID del incidente previamente activo con código HTTP 200 OK, registrando el intento en auditoría en background.

4. GOBERNANZA DEL CICLO DE VIDA DE TOKENS PUSH FCM

Para resguardar la privacidad de los profesionales de la salud y evitar alertas fuera del horario de servicio:

- **Vinculación Segura:** Al autenticarse, la app registra el token FCM del terminal móvil mediante POST `/api/v1/fcm/token`, asociándolo a la sesión activa.
- **Desregistro en Logout:** Al culminar la guardia o cerrar sesión, el terminal ejecuta DELETE `/api/v1/fcm/token`, desactivando el dispositivo para no perturbar al médico fuera de turno.
- **Auditoría de Despacho:** Cada envío push se registra en `incidentes_auditoria_eventos` (tipo NOTIFICACION_PUSH_DESPACHADA) con la latencia medida en milisegundos.

5. REFERENCIAS NORMATIVAS (APA 7.ª EDICIÓN)

American Heart Association [AHA]. (2020). Guidelines for CPR and ECC. *Circulation*, 142(16_suppl_2). <https://doi.org/10.1161/CIR.0000000000000916>

Date, C. J. (2019). *Database design and relational theory: Normal forms and all that jazz* (2.ª ed.). O'Reilly Media.

International Organization for Standardization [ISO]. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC 27001:2022). ISO.